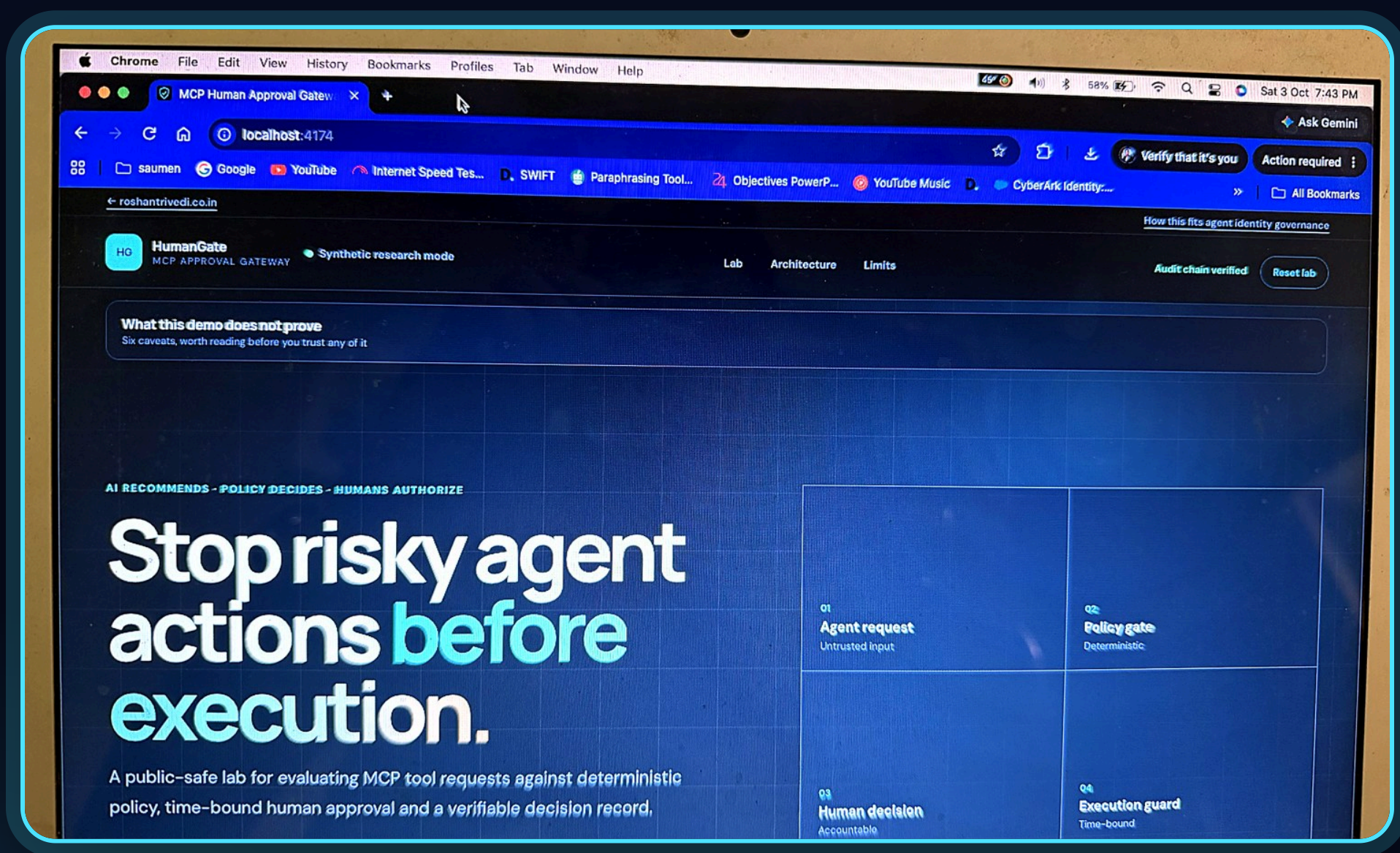


Tested. Proven.

My human guardrails work **before** an AI agent makes a decision. Built on a home laptop. Tested with a real MCP client.



Roshan Trivedi

IAM · PAM · Agentic AI security

AI agents now call tools. Some of them matter.

Search the docs. Read a repo. Change a role. Deploy to production.

Who said yes?

to the dangerous ones

Can we prove it?

afterwards

An agent one prompt away from a production change needs a gate in front of it.

A gate between the agent and the tool

1 · Policy

Fixed rules judge every call: run, refuse, or hold for a person.

2 · Human approval

A reviewer with the right role decides. Agents can't approve themselves.

3 · Bound, single-use

The approval is tied to the exact request, expires fast, works once.

4 · Audit trail

Every decision lands in a hash-chained log anyone can verify.

All tools are synthetic. Nothing real is touched.



Not my own script. **A client I didn't write.**

I used the official **MCP Inspector v2.9.0**, the standard tool for testing MCP servers, over protocol **2025-11-25**.

Then I walked one risky request through the whole path, and tried to break the rules on the way.

Next: nine steps, real screens, photographed as I went.

Lab running on my home laptop

A 2017 MacBook Air. Install, build, start. The gateway listens on localhost and speaks MCP.

```
mcp-human-approval-gateway -- node
Total 366 (delta 24), reused 19 (delta 19), pack-reused 341 (from 1)
olving objects: 100% (366/366), 585.74 KiB | 3.08 MiB/s, done.
olving deltas: 100% (183/183), done.
hans-MacBook-Air:~ roshan$ cd mcp-human-approval-gateway
hans-MacBook-Air:mcp-human-approval-gateway roshan$ npm install
warn EBADENGINE Unsupported engine {
warn EBADENGINE   package: 'mcp-human-approval-gateway@0.1.0',
warn EBADENGINE   required: { node: '>=24' },
warn EBADENGINE   current: { node: 'v22.23.3', npm: '10.9.9' }
warn EBADENGINE }

ed 65 packages, and audited 66 packages in 5s

ackages are looking for funding
un `npm fund` for details

nd 0 vulnerabilities
notice
notice New major version of npm available! 10.9.9 -> 12.2.0
notice Changelog: https://github.com/npm/cli/releases/tag/v12.2.0
notice To update run: npm install -g npm@12.2.0
notice
hans-MacBook-Air:mcp-human-approval-gateway roshan$ npm run build

cp-human-approval-gateway@0.1.0 build
ite build

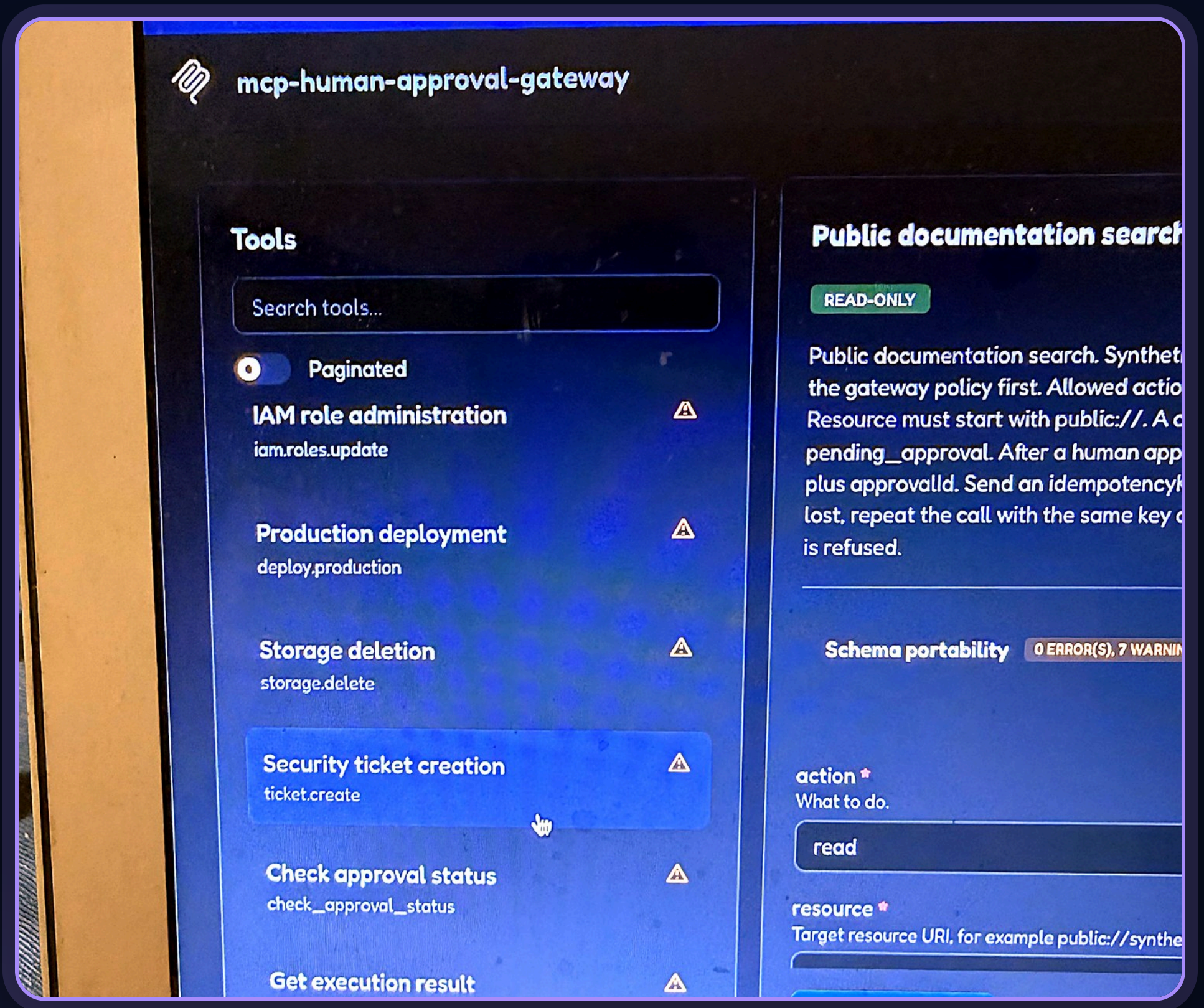
e v6.4.3 building for production...
8 modules transformed.
t/client/index.html                2.30 kB | gzip: 0.79 kB
t/client/assets/index-C2yao1KV.css 31.02 kB | gzip: 6.81 kB
t/client/assets/index-PuR3v7ub.js 299.82 kB | gzip: 93.08 kB
uilt in 1.80s
hans-MacBook-Air:mcp-human-approval-gateway roshan$ npm start

cp-human-approval-gateway@0.1.0 start
ode server/index.js

de:2271) ExperimentalWarning: SQLite is an experimental feature and might change at any time
e `node --trace-warnings ...` to show where the warning was created)
Human Approval Gateway listening on http://127.0.0.1:4174
endpoint: POST http://127.0.0.1:4174/mcp (unauthenticated demo mode)
```

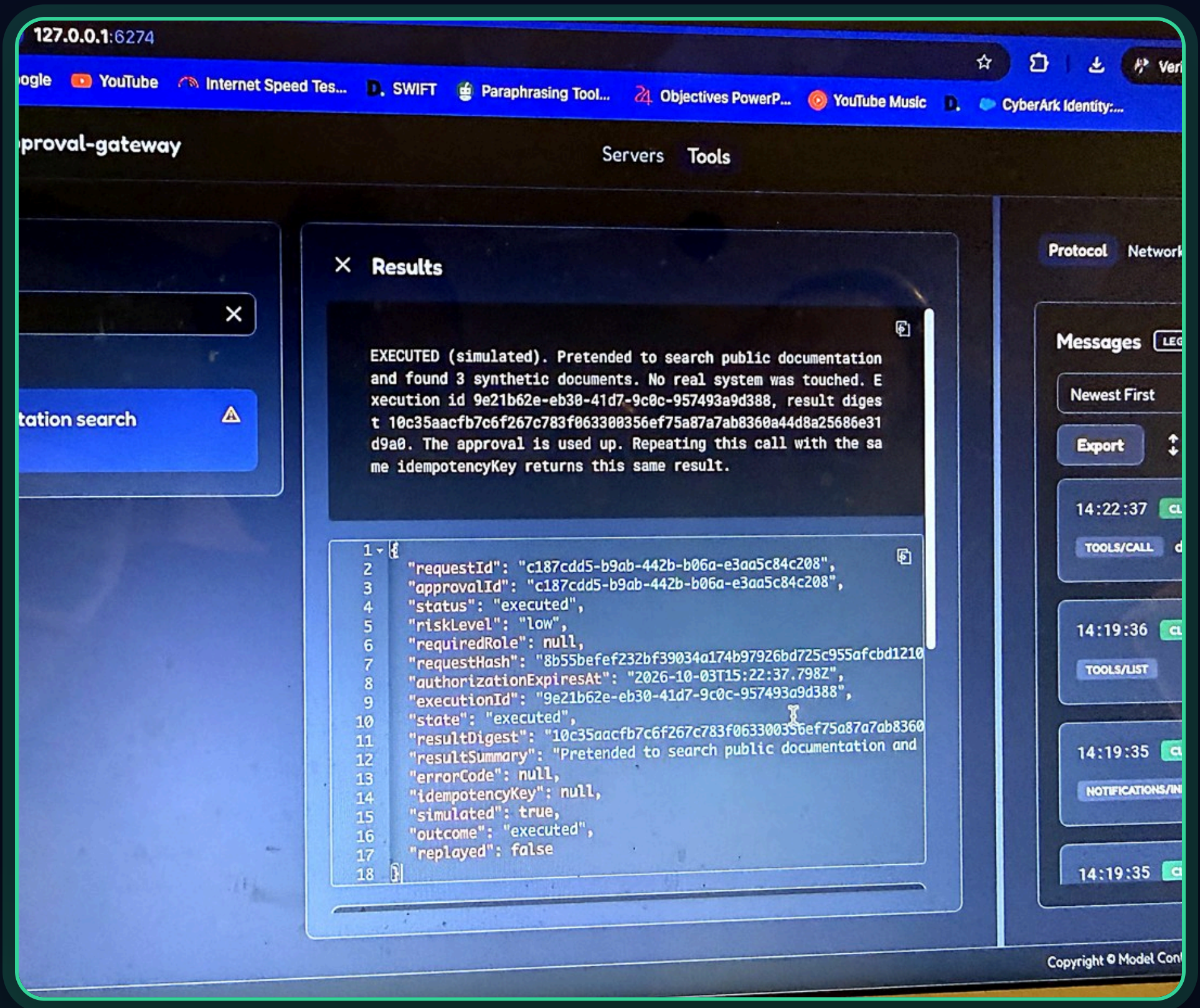
A real client connects

Official MCP Inspector v2.9.0 negotiated protocol 2025-11-25 and found all 9 tools.



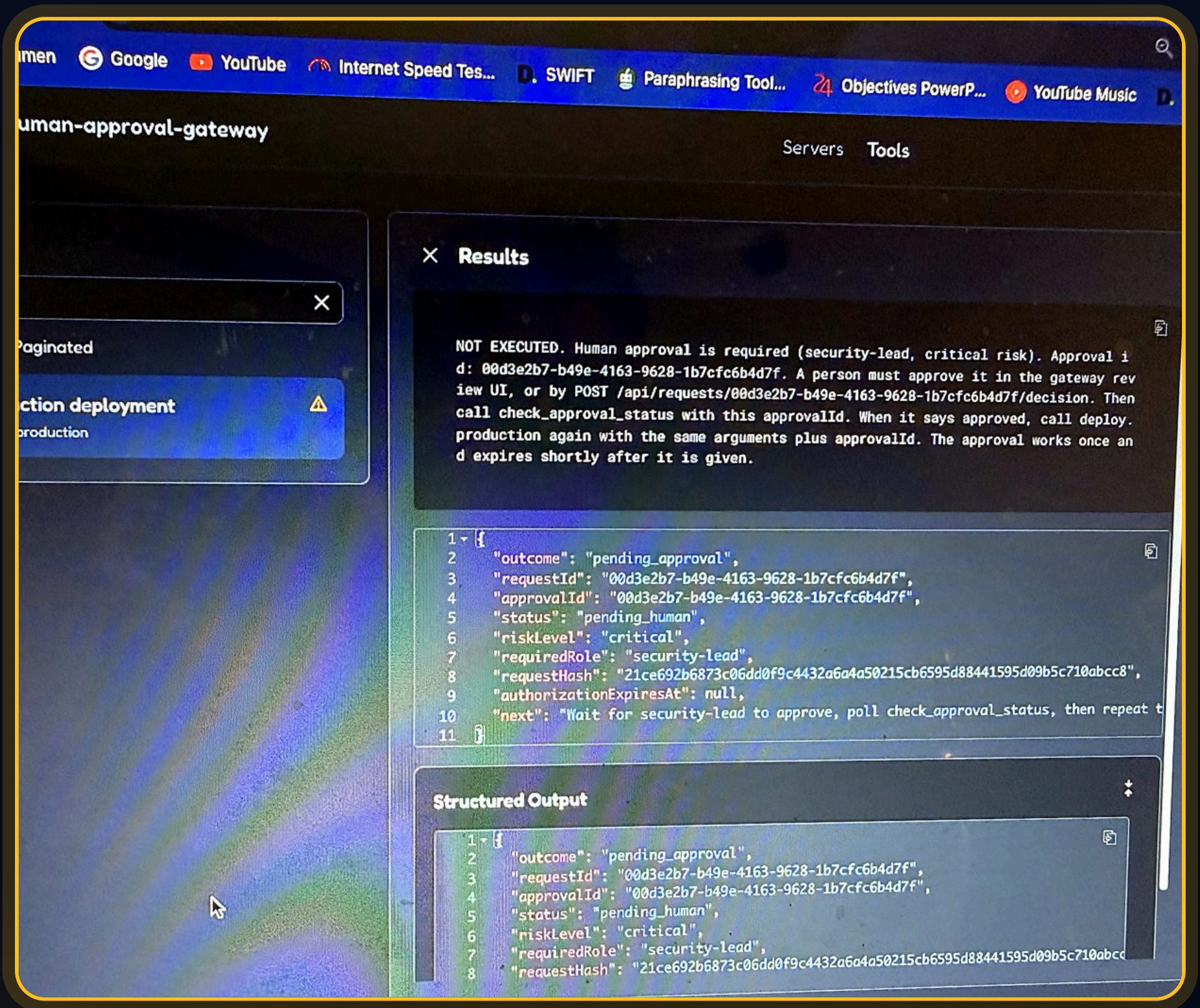
Low-risk request: runs

Public docs search. Risk score 14 of 100. Policy allowed it. No human needed.



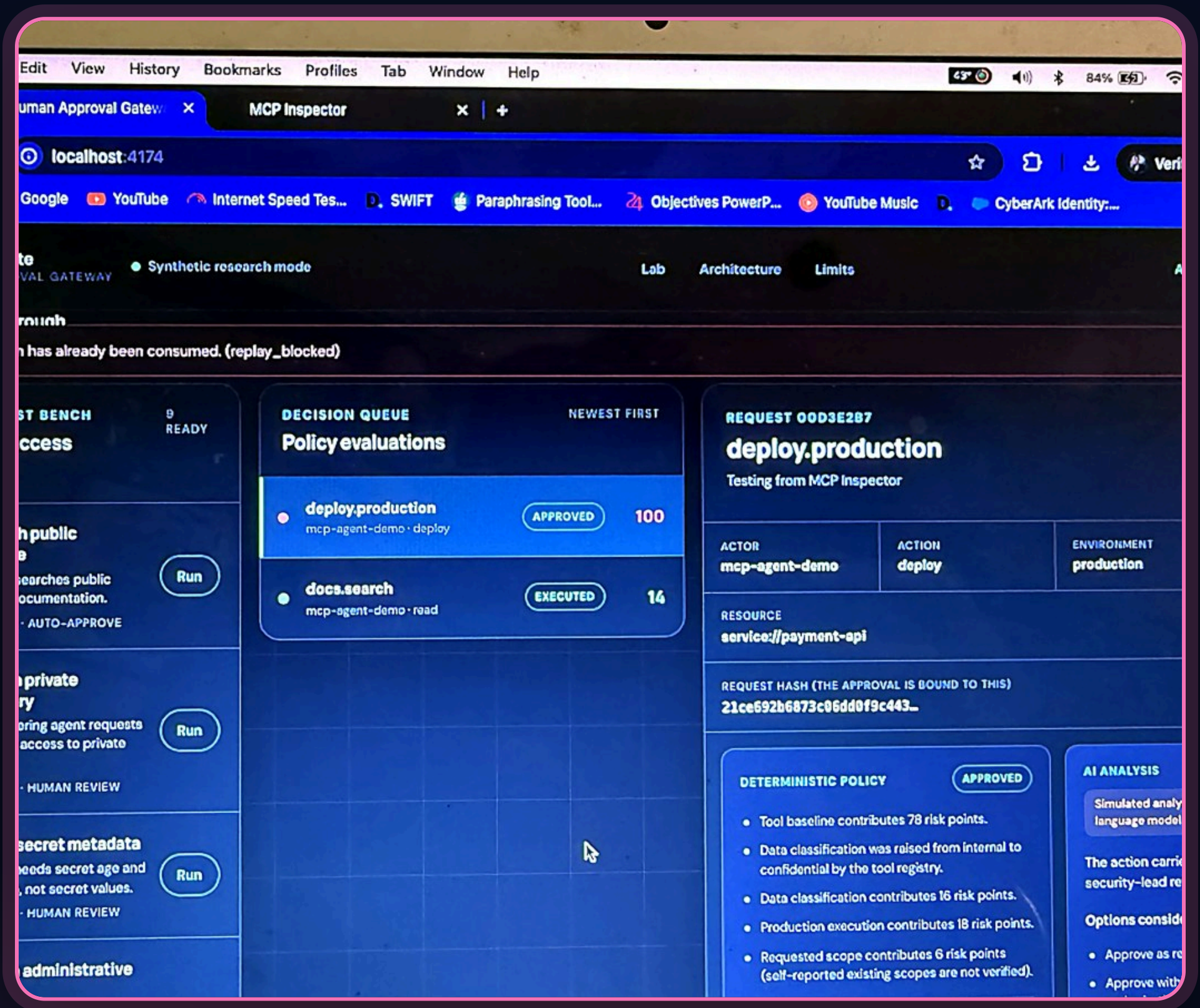
Risky request: held

Production deploy scored 100 and came back as pending approval. Nothing executed.



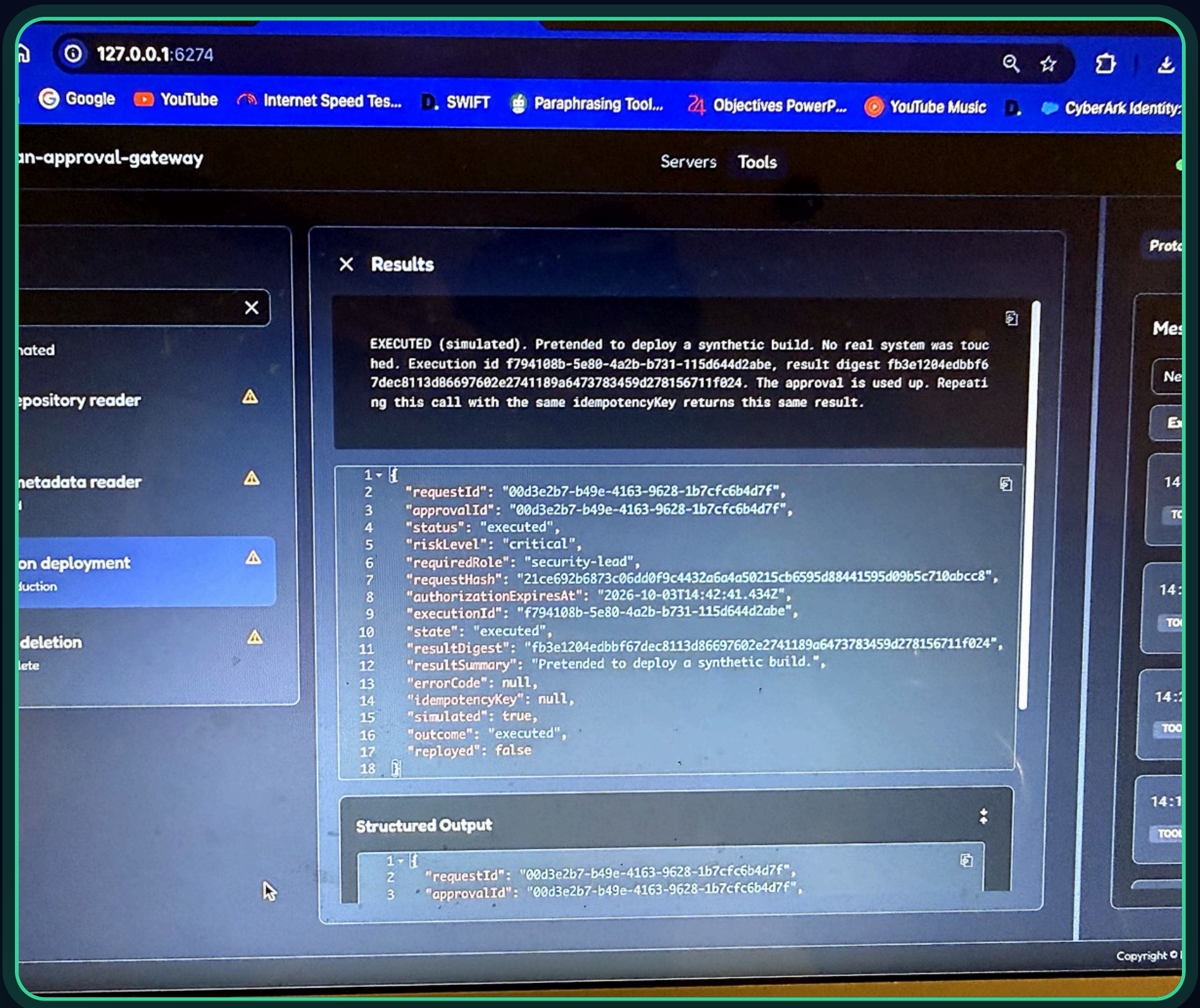
A human decides

Morgan, the security lead, approves in the review screen. The approval is tied to the exact request.



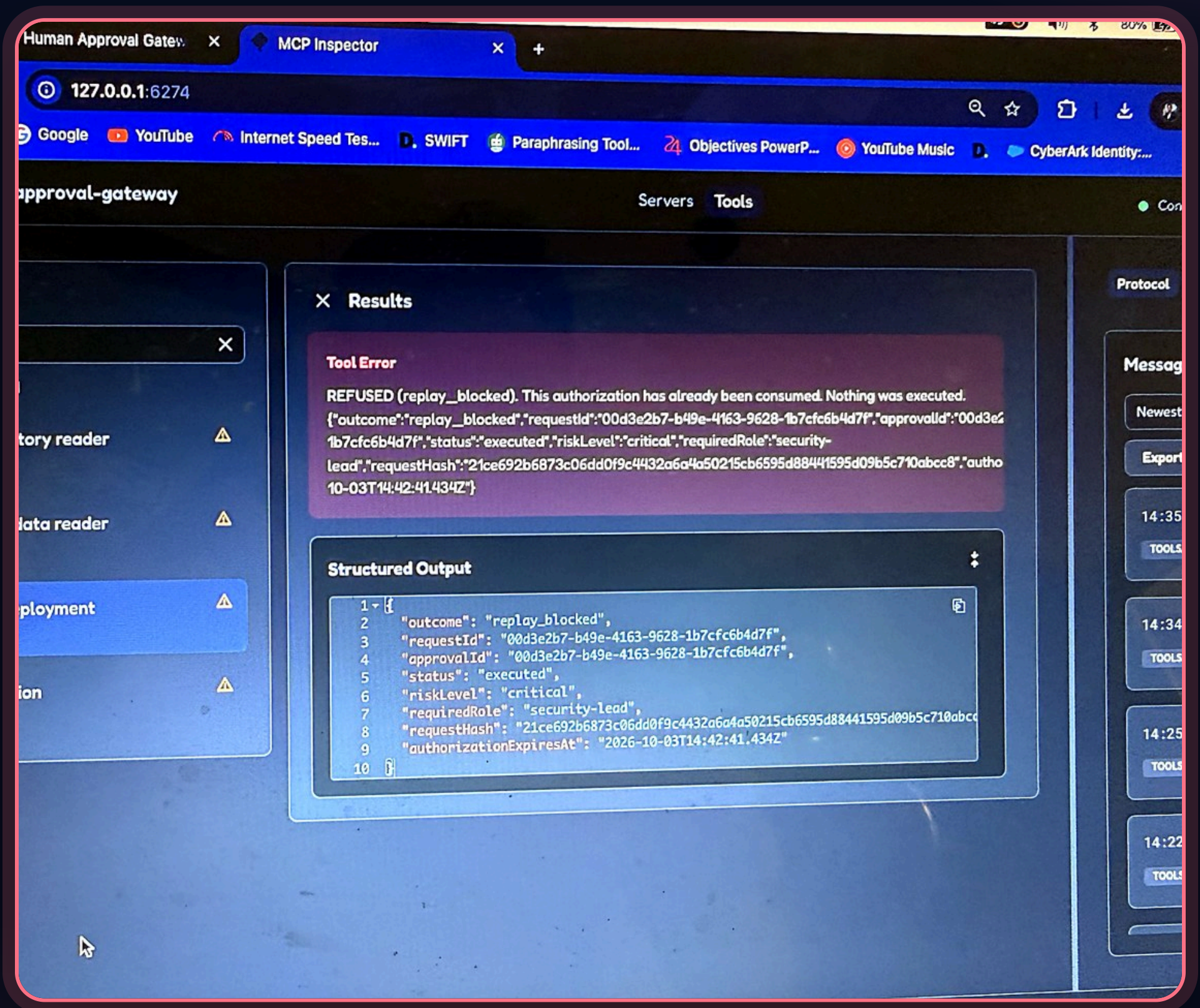
It runs once

Same call, now with the approval ID. Executed, and the approval is marked used up.



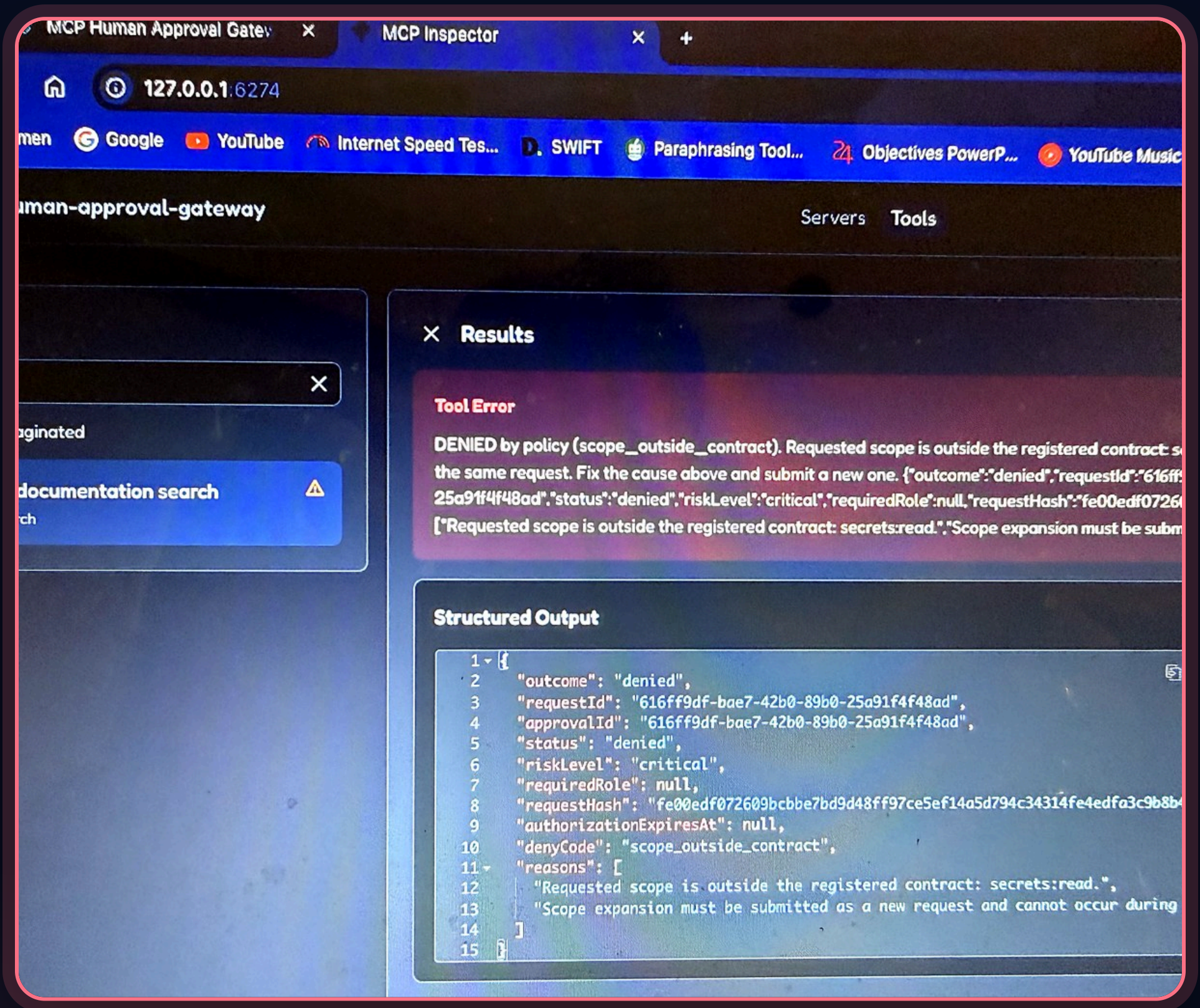
Reuse the approval: refused

Replay blocked. Nothing ran. One approval, one action.



Ask for too much: denied

A search that also asked for `secrets:read` was refused. Scope can't grow quietly.



Everything is on record

Real-client calls labelled MCP. Hash-chained log, 26 events, **chain verified**.

HASH-CHAINED EVIDENCE

Revision record

16 events verified

[Download audit log](#)

dd33d0042a84f927 at event 16 · unsigned (no key configured)

human.approve security-lead:lead-morgan	08:02:41 PM	dd33d0042a84
mcp.tools_call MCP mcp:mcp-agent-demo · tools/call · deploy.production · pending_approval	07:55:36 PM	ddc9af417ab4
ai.analysis_recorded offline-deterministic	07:55:36 PM	b82ef753daee
policy.require_human deterministic-policy	07:55:36 PM	6e783d578b4e
request.submitted mcp:mcp-agent-demo	07:55:36 PM	1f26f7a2cb71
mcp.tools_call MCP mcp:mcp-agent-demo · tools/call · docs.search · executed	07:52:37 PM	70862708e15b
action.confirmed mcp:mcp-agent-demo	07:52:37 PM	3be3a06507f7

Each event hash covers the one before it, so edits, gaps and reordering are detected. A plain hash chain does not stop someone who can access the store and rebuild every hash. That needs a signing key or a head hash saved somewhere the writer cannot reach. The browser shows the chain of events, but the MCP server are labelled mcp.



What the real client showed

Low-risk call	Ran
Production deploy	Held for a human
Reviewer approval	Granted, bound to request
Run with approval	Executed once
Reuse of approval	Refused
Over-scoped request	Denied
Audit trail	Complete, verified

Why it matters

Safe calls stay fast. Only risky ones wait for a person, and there is a record of who allowed what.



What this doesn't prove yet

- It's a lab with **synthetic tools**, not production.
- One client, tested by hand. **Claude Code and others are next.**
- Self-approval, changed-request and status-check tests are still to do.
- The audit log is unsigned.

Details and the lab

roshantrivedi.co.in

github.com/trivediroshan1-ui/mcp-human-approval-gateway